

05 *Don't leave default router passwords or unused admin services enabled*

Why it matters: SentinelOne ranks "default creds" among the top five mis-config sources exploited in 2024 – even beating some zero-days.

Three-step drill

1. Change default user/pass on first boot – before the WAN cable goes live.
2. Disable Telnet, FTP, UPnP, WPS and SNMPv1/v2c on all gear.
3. Enable login banners warning unauthorised access; log every failed attempt to your SIEM.

07 *Do document roles and run a tabletop response exercise yearly*

Why it matters: Teams that rehearse once a year cut mean-time-to-containment by 54 hours, according to Kaspersky's breach-impact study.

Three-step drill

1. Map every breach task to a name – CEO for breach disclosure, HR for employee comms, etc.
2. Pick a single-scenario tabletop (ransomware, power outage) and walk through in real time.
3. Capture gaps; turn them into playbook updates and fresh Jira tickets.

09 *Don't over-license dashboards you never watch – fight tool sprawl*

Why it matters: Concertium's IT-infra audit shows SMEs waste up to 28 % of security spend on unviewed dashboards and duplicate agents.

Three-step drill

1. Inventory every monitoring/SaaS/security licence quarterly; tag "red-unopened" tools.
2. Merge or sunset duplicates (e.g., drop one EDR if your firewall now bundles it).
3. Redirect savings to staff training or hardware refresh.

06 *Don't ignore "small" incidents – they're red flags for bigger breaches*

Why it matters: TechRadar's incident-response survey shows 77 % of ransomware victims had at least three "minor" alerts in the 30 days prior.

Three-step drill

1. Treat every repeated IPS block or AV pop-up as a ticket.
2. Tag clusters of related alerts in your SOC tool; look for lateral movement.
3. After action, update rules to auto-escalate similar events.

08 *Do back up configs off-device and test restores quarterly*

Why it matters: Cisco's configuration-management white paper and First Exchange Bank's own IT policy both recommend quarterly off-box backups to survive device failure and admin error.

Three-step drill

1. Automate nightly pulls via Oxidized or RANCID to Git.
2. Schedule a calendar reminder every quarter: pick one switch, factory-reset it, and restore from Git.
3. Store an encrypted copy of the repo off-site or in a cloud bucket with MFA.

10 *Do run an annual Wi-Fi + camera heat-map survey*

Why it matters: Office remodels, glass partitions and new IoT devices create invisible RF and sight-line blind spots. Ekahau and Aruba both advise yearly re-surveys – even sooner after major layout changes.

Three-step drill

1. Update the floorplan; mark new cubicles, walls and shelves.
2. Walk the grid with Ekahau HeatMapper (for Wi-Fi) and a phone camera on a pole (for VIGI sight lines).
3. Relocate APs or cameras until coverage is 100 % "green" on the overlay. 